

Mimikatz 架构与模块组成

Mimikatz 是法国安全研究员 Benjamin Delpy (gentilkiwi) 于2007年以C语言编写的 Windows 工具¹，支持 x86/64 系统。它的核心设计采用模块化架构，各模块实现不同功能。二进制中包含主程序与可选组件：**mimidrv**（数字签名的内核驱动，用于绕过内核保护）和 **mimilib**（供 WinDbg 调试、AppLocker 绕过、密码过滤钩子等）¹。运行 Mimikatz 需要 **管理员 (Administrator) 或 SYSTEM 权限**，并通常需要开启调试特权 (Debug Rights) 才能读取受保护的内存^{1 2}。

Mimikatz 的主要模块包括：**sekurlsa**（与 LSASS 进程交互，从内存中提取凭据）、**kerberos**（操作 Kerberos 票据，包括金票/银票的生成与注入）、**lsadump**（利用域复制协议获取或操纵 AD 数据，如 DCSync、DCShadow、SAM 转储、信任密钥等）、**crypto**（绕过受保护机制导出证书及私钥）、**dpapi**（提取被 DPAPI 保护的凭据）、**vault**（导出 Windows 凭据管理器中的凭证），以及其他辅助模块如 **privilege**（提升调试权限）、**service**（控制服务）、**process**（进程查询与注入）、**rpc**（远程控制）、**misc**（包括注入 Skeleton Key 等）等^{3 4}。例如，**sekurlsa** 模块可通过 `sekurlsa::logonpasswords`、`sekurlsa::msv`、`sekurlsa::kerberos`、`sekurlsa::pth` 等命令导出当前或最近登录用户的密码、哈希及 Kerberos 票据；**kerberos** 模块（如 `kerberos::golden`、`kerberos::ptt`）用于伪造和注入 Kerberos 凭据；**lsadump** 模块可执行 `lsadump::dcsync`（远程请求域控制器同步账号密码）、`lsadump::lsa`（获取域控制器上 AD 凭据）、`lsadump::trust`（获取信任关系密码）、`lsadump::sam`（提取本地 SAM 哈希）等操作^{5 6}。下表示例展示了部分常用命令（未经穷举）：

- **sekurlsa::logonpasswords** – 从 LSASS 内存中转储登录凭据，包括 NTLM 哈希和（老版本 Windows）明文密码⁶。
- **sekurlsa::pth** – Pass-the-Hash 攻击，可用指定用户的 NTLM 哈希伪造令牌并运行进程⁷。
- **sekurlsa::tickets** – 列出当前会话中的 Kerberos 票据。
- **kerberos::golden** – 生成 Golden Ticket；**kerberos::ptt** – Pass-the-Ticket 注入票据^{8 5}。
- **lsadump::dcsync** – 模拟域控制器请求同步某账号（如 krbtgt 或 Administrator）的密码哈希⁹。
- **lsadump::lsa::trust** – 直接从 DC 上的 LSA 服务提取域内所有凭据或信任关系密码。
- **misc::skeleton** – 在域控制器上注入“Skeleton Key”后门，使该 DC 接受一个自定义“万能密码”¹⁰。

以上模块构成了 Mimikatz 的功能体系，使其成为 AD 环境下的“瑞士军刀”，能直接从内存和域复制协议中获取各种凭据^{3 4}。下图所示为其主要模块示例：

核心实现原理

Mimikatz 的核心在于读取并解析 LSASS (Local Security Authority Subsystem Service) 进程内存中的凭据信息。Windows 在用户登录后会在 LSASS 内存中保留多种认证凭据（包括 NTLM/LM 哈希、Kerberos 票据以及为支持某些 SSP（如 WDigest、LiveSSP）而加密存储的明文密码）^{11 12}。Mimikatz 先通过 **OpenProcess** 等 API（结合 `PRIVILEGE::Debug` 授予的调试权限）打开 LSASS 进程句柄，然后使用 **ReadProcessMemory** 等 API 从其内存中读取内容^{13 2}。为了定位凭据，Mimikatz 对 `lsasrv.dll` 中的结构体（如 `LogonSessionList`）进行模式扫描；不同 Windows 版本有不同的内存布局，Mimikatz 会使用针对每个版本的特征进行匹配¹³。读取到内存块后，Mimikatz 分析 LSASS 内部的认证包（MSV1_0、WDigest、Kerberos 等）结构，提取如用户名、域、密码哈希等字段。

对于加密存储的密码（如 WDigest/LiveSSP 在内存中的“加密”密码），Windows 使用 `LsaProtectMemory/LsaUnprotectMemory` 函数进行加密保护^{14 15}。具体而言，SSP 模块会用 `LsaProtectMemory` 加密凭据并留在内存中。Mimikatz 则调用对应的 `LsaUnprotectMemory` API 对这些片段解密，从而直接获得明文密码^{14 15}。正如分析所指出：“Mimikatz 可以直接从内存中提取加密凭据，并通过 `LsaUnprotectMemory` 将其解密为明文密码”¹⁴。这一流程依赖于进程有调试权限或系统权限；如果权限不足，Mimikatz 也可以先使用 `token::elevate` 模块假冒系统权限。值得注意的是，Windows 8.1/2012 R2 以后出于安全考虑不会再默认将用户明文密码留在内存（通过 KB2871997 回执补丁可为老系统启用此防护）¹⁶，因此在新系统上 `sekurlsa::logonpasswords` 一般只能看到哈希而非明文。

有时为了避免被防护监测或在非调试环境下，攻击者可采用**转储 LSASS 内存**的方式（如使用任务管理器、`procdump`、`rundll32+comsvcs.dll` 等工具）将整个 LSASS 进程内容导出到文件，然后离线分析。Mimikatz 的 `sekurlsa::minidump` 模块可加载这些 .dmp 文件进行分析¹⁷。此外，Mimikatz 也可加载自带的数字签名驱动 `mimidrv.sys` 来解除对 LSASS 的保护标记，通过 `!processprotect` 命令删除 PPL 保护，从而在启用 PPL（Protected Process Light）的系统上也能读取 LSASS¹⁸。

各类攻击技术

明文密码提取与凭据转储

在获得足够权限后，最直接的攻击是利用 `sekurlsa::logonpasswords` 等命令从 LSASS 内存中转储登录会话的凭据。此命令将列出当前或近期登录用户的用户名、域、以及 MSV (NTLM) 哈希和（若存在）明文密码、以及 Kerberos 票据等⁶。在早期 Windows 中（启用 WDigest 的情况下），Mimikatz 可获得明文密码。例如，对于一个新登录的用户凭据，LSASS 会将密码加密后与密钥一同存储；Mimikatz 读出后用 `LsaUnprotectMemory` 解密即得明文¹⁴。密码管理器（CredMan）和 DPAPI 主密钥也可通过 `sekurlsa::credman`、`sekurlsa::dpapi` 等子命令导出。需要注意的是，新版 Windows 默认关闭了 WDigest 明文缓存功能，所以在新版系统上通常只能看到 NTLM/NTLMv2 哈希¹⁶。此外，如果先导出 LSASS 转储文件（例如使用 `sekurlsa::minidump`），则无需系统特权也可进行分析。

哈希重用（Pass-the-Hash）

Mimikatz 支持经典的“Pass-the-Hash”攻击。通过 `sekurlsa::pth /user:用户名 /domain:域名 /ntlm:哈希 /run:命令` 命令，Mimikatz 会启动一个指定运行命令的进程，并用给定的 NTLM 哈希替换掉流程令牌中的密码哈希，从而以该用户身份运行命令而无需知晓真实密码⁷。新版 Mimikatz 还扩展了“Over-Pass-the-Hash”功能，在 Kerberos 票据中注入 NTLM 哈希（或 AES 密钥），允许在启用了 AES 强制的环境下仍通过哈希发起认证⁷。此命令需要管理员或 SYSTEM 权限（因为要操作进程令牌）。如资料所示，执行 `sekurlsa::pth` 时会启动新进程并用假凭据替换之，实现凭据伪造⁷。这对提权和横向移动非常有效，因为可以直接在没有密码的情况下利用哈希登陆其他计算机。

票据重用（Pass-the-Ticket）

Mimikatz 提供 `sekurlsa::tickets` 和 `kerberos::ptt` 等功能用于 Kerberos 票据重用。首先，攻击者可以通过 `sekurlsa::tickets /export` 导出当前用户或系统的有效票据（.kirbi 文件），包括 TGT 和 TGS。然后，可用 `kerberos::ptt /ticket:票据文件` 将这些票据注入当前会话，完成票据重用。更常用的是针对此前窃取或伪造的票据（如 Golden/Silver Ticket），直接使用 `kerberos::ptt` 将其载入当前用户的凭据缓存⁵。正如资料中所示，`KERBEROS::PTT` 典型用途就是注入窃取或伪造的 Kerberos 票据（包括金票、银票或信任票）⁵。注入后，系统就认为当前会话持有合法票据，可直接访问对应的资源。与 Pass-the-Hash 类似，票据重用可以在跨域、跨服务访问中绕过传统认证。

Golden Ticket（金票）

金票攻击 是最强大的持久化手段之一。金票本质上是伪造的 Kerberos TGT，使用域中 KRBtgt 账户的秘密（NTLM 或 AES 哈希）加密和签名⁸。攻击者需先通过 DCSync 或其他手段获取 KRBtgt 账号的哈希，然后运行

```
kerberos::golden /domain:域名 /sid:域SID /krbtgt:KRBtgt哈希 /user:要伪造的用户名 /groups:组列表 /ptt
```

等命令创建金票^{8 19}。生成后该票据可以使攻击者以被伪造用户（如域管理员）身份访问任何域内资源。正如资料中指出：“金票可以用来模拟域中任何用户（真实或虚构），并作为任何组成员获取对任何资源的访问，因为它在整个域范围内有效⁸。”攻击成功后，攻击者就拥有几乎**无限权利**，并可设置很长的有效期而绕过密码更改。检测方面，可以注意异常的 TGT 请求和不合逻辑的账户访问等。金票防御的关键是定期双重重置 KRBtgt 密码（间隔大于 Kerberos 最大票据寿命）以使所有旧票据失效¹⁹。资料建议“将 KRBtgt 密码更新两次可以确保任何用已窃取的密钥签名的旧票据全部失效”¹⁹。

Silver Ticket（银票）

银票攻击 针对特定服务。银票是伪造的 Kerberos TGS（服务票），使用目标服务账号（通常是运行该服务的机器或服务主体的账号）NTLM 哈希加密签名²⁰。Mimikatz 也使用 `kerberos::golden` 命令生成银票，只需提供 `/rc4`（NTLM 哈希）或 `/aes` 参数以及 `/service:服务SPN` 等信息。正如说明所述：“银票是使用目标服务账户 NTLM 哈希对 TGS 进行加密签名的票据”²⁰。通过伪造的银票，攻击者可以访问对应服务（如文件服务器、数据库等）而无需真正的域控制器交互。不过银票局限于目标服务，不能像金票那样跨整个域。

DCSync（复制同步）

Mimikatz 的 `lsadump::dcsync` 功能允许攻击者模拟一个域控制器并通过 Microsoft 目录复制服务协议（MS-DRSR）从真正的 DC 获取账户密码哈希⁵。运行类似 `lsadump::dcsync /domain:DOMAIN /user:krbtgt` 的命令即可从 DC 同步 `krbtgt` 或其他账户（如 Administrator）的 NTLM 哈希⁵。这一过程无需在目标域控制器上执行代码，只需攻击者拥有合适的复制权限（通常是域管理员或专门委派权限）^{5 9}。一旦获得哈希，攻击者即可进行金票攻击或直接在网络中以该账户身份横向移动。正如研究所指出，“DCSync 攻击可用来获取 KRBtgt 密钥，通常在进行金票攻击前使用”⁹。

Skeleton Key（骨架键）

Skeleton Key 攻击是一种在域控制器上植入后门的技术。Mimikatz 的 `misc::skeleton` 命令会在 DC 的 LSASS 中注入一段“万能密码”代码，使得该 DC 在验证用户时，除了正常密码外，还接受攻击者设置的另一个“主密码”¹⁰。执行后，该 DC 对所有用户（包括域管理员）都允许使用这一主密码登录，极难检测。资料中描述：“在域控制器的 LSASS 进程中注入 Skeleton Key 后门，使得该 DC 允许使用‘万能密码’以及正常密码进行身份验证”¹⁰。此攻击需要对 DC 拥有管理员权限，且对网络造成持久威胁。为防护，可监控 DC 上的 LSA 事件、定期检查后门程序，并尽量限制 DC 管理权限。

（备注：Mimikatz 的 `lsadump` 模块还包括 `DCShadow` 等功能，用于向 AD “投毒”复制数据，增强持久性，不过这里重点介绍核心攻击。）

与 Windows 安全机制的交互

近年来，Windows 引入多项机制对抗 LSASS 凭据窃取：**LSA 保护（PPL）**、**Credential Guard**、**WDigest 明文缓存禁用**等。Mimikatz 对这些机制的应对策略如下：

- **LSA 保护 / PPL (Protected Process Light)**：启用 PPL 后，LSASS 进程被标记为受保护进程，非签名代码无法打开其内存句柄。默认情况下，Mimikatz 等用户态程序会被阻止读取 LSASS。对此，Mimikatz 通过其数字签名驱动 `mimidrv.sys` 绕过保护：加载驱动后执行 `!processprotect /`

`process:lsass.exe /remove` 将移除 LSASS 的保护标记¹⁸。如资料所示：“为绕过 PPL，我们可让 Mimikatz 加载 `mimidrv.sys`（一个签名驱动），以移除 LSASS 进程的保护标志”¹⁸。此后 Mimikatz 恢复对 LSASS 的读取和处理。总结来说，如果系统开启了 PPL，只要 `mimidrv` 驱动可用，Mimikatz 仍能恢复访问。

- **Credential Guard**：Windows Defender Credential Guard 使用虚拟化安全（VBS）将凭证隔离到专门容器中，用户态代码无法直接访问。²¹ 指出：“Credential Guard 使用虚拟化技术将凭据存放在与操作系统隔离的容器中”。启用该功能的系统上，普通 Mimikatz 已无法直接读取 LSASS 中的凭据。绕过方式包括：内部记忆法（Internal Monologue，利用已提权的管理员通过 LSA RPC 读取散列）、安装恶意 SSP 钩子等²²。例如资料提到安装新的安全支持提供程序可以在今后捕获输入的密码²³。总之，启用 Credential Guard 后标准手段难以获取凭证，但仍需防范物理/硬件旁路和内存交换等高级攻击。
- **WDigest 明文禁用**：自 Windows 8.1 起，Microsoft 默认禁用 WDigest 凭证的明文存储，极大减少了 Mimikatz 获取明文密码的机会。¹⁴ 和 ²⁴ 均提到这方面的强化。建议在旧系统上手动禁用 WDigest（关闭 `HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest\UseLogonCredential`），避免明文密码被缓存。
- **其他**：Windows 还支持仅在签到时缓存最少凭据、使用引导级别的内存加密等。尽管如此，Mimikatz 利用了认证系统本身设计的机制（如可逆加密、票据共享）进行提权，因此要真正防御，需要复合措施。防护建议包括：限制管理员权限、移除默认的 Debug 权限、启用 Credential Guard 和 LSAPPL、定期重置 KRBGT 密钥对¹⁹等。

实际操作流程示意与使用注意事项

以下给出一个典型靶场环境中的 Mimikatz 使用流程示例（均在授权的测试环境中进行）：

1. **获取高权限**：首先在目标机器（如已被利用后的客户端或管理服务器）获得 Administrator 或 SYSTEM 权限（例如利用漏洞、`psexec` 等手段）。
2. **启动 Mimikatz**：使用管理员身份打开命令行，运行与系统位数匹配的 Mimikatz 可执行文件（32 位或 64 位）。进入交互界面后，可先执行 `version` 检查系统和程序信息²⁵。
3. **提升调试权限**：输入 `privilege::debug`（或 `token::elevate`）命令，为当前进程激活调试特权（预期输出“Privilege '20' OK”）²⁶。这一步是读取 LSASS 必不可少的权限。
4. **导出凭据**：
5. (a) **明文密码/H26哈希**：运行 `sekurlsa::logonpasswords` 将列出内存中所有登录会话的凭据，包括用户名、NTLM 哈希（在旧系统可能有明文密码）⁶。可用 `log` 命令将结果保存到文件²⁷。
6. (b) **Kerberos 票据**：使用 `sekurlsa::tickets /export` 导出现有票据或 `kerberos::list` 查看当前用户票据。通过 `kerberos::ptt /ticket:文件路径` 将票据注入当前会话实现票据重用⁵。
7. (c) **金/银票**：若已知 KRBGT 哈希，可执行 `kerberos::golden /domain:例域名 /sid:域SID /krbtgt:Hash /user:Admin /groups:512,519 /aes256:Hash /ptt` 来伪造一个域管理员的金票并注入内存⁸。类似地，提供服务账户哈希和 `/service:SPN` 参数可生成银票²⁰。
8. (d) **DCSync**：在域环境中，如会话有域管理员权限，可执行 `lsadump::dcsync /domain:FQDN /user:krbtgt` 等命令，直接从域控制器同步获取指定账户（如 `krbtgt` 或 Administrator）的哈希⁹。
9. (e) **Skeleton Key 注入**：若目标是域控制器，可运行 `misc::skeleton` 在 DC 的 LSASS 中植入骨架键（需管理员权限）¹⁰。
10. **清理**：测试完成后，退出 Mimikatz 并删除可能留下的文件/日志。若使用了 `mimidrv` 驱动，应卸载它以恢复系统保护。

注意事项：

- **仅限授权环境：**所有操作必须在合法授权的测试环境中进行，禁止在未授权机器上使用 Mimikatz²⁸。Mimikatz 本质上利用了已经获得的高权限进行后续操作，因此不应被用于非法入侵。
- **防杀软扫描：**Mimikatz 易被杀毒/EDR 检测为恶意。为演练可暂时禁用防护或使用免杀版本，并尽量在隔离实验室环境中操作。
- **凭据安全：**转储的凭据非常敏感，务必妥善保管演练数据，避免泄露生产环境用户密码。
- **系统兼容性：**根据目标 Windows 版本选择正确的 Mimikatz 版本（32/64位）。在 Windows 8.1 及以上系统，明文密码通常不可见；在启用了 Credential Guard 的系统上，Mimikatz 默认无法读取内存凭据²¹。
- **权限清理：**实验结束后，应撤销测试中授予的额外权限（如去除 Debug 权限）并重置被修改的 AD 账户（如 krbtgt 重置密码两次）¹⁹。

检测与防御措施简述

针对 Mimikatz 和相关凭据窃取活动，安全团队可采取多层防御和检测策略：

- **行为检测：**监控 LSASS 进程的异常行为，例如**频繁访问/读取 LSASS 内存**（NtReadVirtualMemory 调用）或 CPU 利用率飙升²⁹。现代 EDR 可识别 Mimikatz 对 lsasrv.dll 的扫描模式；检测对 MiniDumpWriteDump、PssCaptureSnapshot 等 API 的调用也可发现可疑内存导出行为^{13 29}。
- **脚本和进程审计：**开启 PowerShell 脚本块日志，对 Mimikatz 常见命令（如 Invoke-Mimikatz、sekurlsa::logonpasswords、kerberos::golden 等）进行搜索²⁹。监控系统中运行的进程和命令行，警惕包含“mimikatz”、“gentilkiwi”等关键字的活动³⁰。同时注意攻击者常用的 LOLBIN（如 procdump.exe、comsvcs.dll、taskmgr.exe）异常用法³¹。
- **认证异常检测：**Pass-the-Hash/Pass-the-Ticket 攻击常导致不同于正常模式的身份验证事件。如同一帐户从多个位置快速登录、Kerberos 请求频次骤增或跨域 SID 不合理等，都可作为告警³²。SIEM/UEBA 系统可利用这些模式发出警报。
- **凭证保护：**启用 **Windows Credential Guard** 和 **LSA 保护** 是有效防御手段³³。Credential Guard 利用虚拟化安全将凭据隔离，阻断了大部分内存窃取手段；LSA 保护 (PPL) 要求与 LSASS 交互的代码必须签名，大幅增加攻击难度³³。同时，**禁用 WDigest** 明文凭证存储，确保内存只保存不可逆的哈希。³⁴指出，禁用 WDigest 会防止明文密码留在内存中。
- **最小权限原则：**严格限制管理员和敏感账户的使用范围和数量^{35 36}。关闭默认给予管理员的 Debug 权限和密码缓存，实施 Just Enough Administration (JEA) 等策略³⁶。每台系统使用唯一的本地管理员密码，避免横向凭证复用³⁵。定期审计和回收不必要的域管理员权限可以减少 Mimikatz 的攻击面。
- **密钥轮换：**作为防范金票攻击的关键步骤，应定期（如半年以内）对 KRBtgt 账户执行**双重重置**（每次重置后等待超过 Kerberos 最大票据寿命）¹⁹。这样可以使任何旧的金票立即失效。
- **日志审查：**集中审查安全日志，特别是来自域控制器的 LSA 事件（如 Event ID 4624/4672 等）和本地安全事件（Event ID 10 – LSASS 快照阻止），及时发现异常登录或凭证访问。
- **威胁情报与规则：**利用最新的 MITRE ATT&CK 情报（T1003 Credential Dumping、T1550 Use Alternate Authentication Material 等）及厂商威胁检测（如微软 LSASS ASR 规则³⁷）阻断和检测 Mimikatz 技术行为。

以上措施结合使用可有效提高对 Mimikatz 等工具的抗性。必须认识到，Mimikatz 本身并非恶意，而是利用了 Windows 认证设计上的内在弱点；因此技术防护与流程管理并行同等重要³⁸。只有在授权环境下熟练掌握 Mimikatz 的实现与使用细节，才能帮助安全团队设计出更有针对性的监测和防御策略，及时识别并阻止潜在的凭据窃取活动。

参考文献：本文引用了多篇公开资料，包括 Mimikatz 官方指导、ADSecurity 博客、厂商研究文章等^{1 14 13 6 8 5 29 39 19 18 28}（出处见标注）。以上信息仅供授权安全测试和研究之用，不得在未经允许的网络环境中使用。

1 3 11 15 **Mimikatz and Active Directory Kerberos Attacks – Active Directory & Azure AD/Entra ID Security**

<https://adsecurity.org/?p=556>

2 4 5 6 7 8 10 16 17 20 28 **Mimikatz – Active Directory & Azure AD/Entra ID Security**

https://adsecurity.org/?page_id=1821

9 19 **Understanding the Golden Ticket Attack | CovertSwarm**

<https://www.covertswarm.com/post/the-golden-ticket-attack>

12 13 **Detecting Credential Stealing with Cortex XDR - Palo Alto Networks Blog**

<https://www.paloaltonetworks.com/blog/security-operations/detecting-credential-stealing-with-cortex-xdr/>

14 **Mimikatz and password dumps | Ivan's IT learning blog**

<https://ivanitlearning.wordpress.com/2019/09/07/mimikatz-and-password-dumps/>

18 21 22 23 **Bypassing LSA Protections < BorderGate**

<https://www.bordergate.co.uk/bypassing-lsa-protections/>

24 25 26 27 36 39 **What is Mimikatz? The Beginner's Guide**

<https://www.varonis.com/blog/what-is-mimikatz>

29 30 31 32 33 34 35 38 **What Is Mimikatz? Definition, Attack, Prevention | Proofpoint US**

<https://www.proofpoint.com/us/threat-reference/mimikatz>

37 **Detecting and preventing LSASS credential dumping attacks | Microsoft Security Blog**

<https://www.microsoft.com/en-us/security/blog/2022/10/05/detecting-and-preventing-lsass-credential-dumping-attacks/>